



REPORTE DE AUDITORÍA DE SEGURIDAD

Fecha: 6 Abril 2026
Auditor: Diego (Security Bot)
Objetivo: /home/jarvis/dept-dev/backend/
Total Vulnerabilidades: 16 (3 HIGH, 8 MEDIUM, 5 LOW)



VULNERABILIDADES HIGH

#	Vulnerabilidad	Archivo	Corrección
1	Contraseñas hardcodeadas en seed.js	src/seed.js	Eliminar seed.js de producción o mover a archivo externo
2	JWT_SECRET con fallback hardcodeado	auth.js, authController.js	Generar nuevo secret: openssl rand -hex 32
3	IP privada hardcodeada	usuariosController.js:152	Usar variable BASE_URL de entorno



VULNERABILIDADES MEDIUM

#	Vulnerabilidad	Archivo	Corrección
1	Dependencias Azure Identity vulnerables	package.json	npm audit fix --force
2	Rate limiting solo en login	middleware/	Agregar rate limiting a /recuperar, /reset-password
3	Validación débil en input recuperación	routes/auth.js	Validar formato de email y token
4	Token de recuperación en logs	authController.js	Remover console.log de tokens

5	CORS sin orígenes específicos	server.js	Especificar orígenes permitidos explícitamente
6	Sin helmet.js configurado	server.js	Agregar Helmet middleware
7	Puerto 3001 expuesto sin restricción	server.js	Agregar whitelist de IPs
8	No hay sanitización de inputs	routes/*.js	Usar express-validator o sanitización manual

VULNERABILIDADES LOW

#	Vulnerabilidad	Archivo	Corrección
1	Usuarios predecibles en seed	src/seed.js	Usar nombres únicos para seeds
2	Error messages revelan información	routes/*.js	Usar mensajes genéricos de error
3	Puerto SQL Server 1433 expuesto	database.js	Restringir acceso a BD por IP
4	Sin HSTS configurado	server.js	Agregar strict-transport-security
5	Stack traces en producción	server.js	Desactivar errorHandler en prod

COMANDOS PRIORITARIOS

```
# 1. Generar JWT_SECRET nuevo
openssl rand -hex 32

# 2. Actualizar dependencias
cd /home/jarvis/dept-dev/backend && npm audit fix --force

# 3. Agregar a .env
JWT_SECRET=nuevo_secret_generado
BASE_URL=http://localhost:3001

# 4. Firewall (producción)
sudo ufw deny 3001/tcp
sudo ufw allow from TU_IP to any port 3001
```

RESUMEN EJECUTIVO

Resultado: El backend necesita mejoras de seguridad antes de producción.

Puntos Fuertes: Usa parameterized queries (buena práctica SQL), bcrypt para passwords, JWT para auth.

Crítico: Eliminar secrets hardcodeados y configurar variables de entorno.

Generado por Diego Security Bot • Proyecto INTRANET IA • 2026